

Unit 1 Introduction to Cyber Security

1.1 Introduction to Cyber Space and Cyber Security

Cyberspace is basically the **virtual world** created by all the interconnected computers, networks, servers, mobile devices, IoT gadgets, cloud services everything digital that talks to each other. Think of it as a massive, invisible space where information flows, people communicate, businesses run, governments operate, and yes... criminals operate too.

It's not a physical place, but the effects are very real money moves, power grids turn on/off, personal secrets get exposed, wars can start or be influenced. Cyber security exists because this space is borderless, always-on, and full of both good and bad actors.

Cyber security (or cybersecurity) is the practice of **protecting** systems, networks, programs, and data from digital attacks, damage, or unauthorized access. It's about making sure the good guys can use cyberspace safely while stopping the bad guys from causing harm.

1.2 CIA Triad: Confidentiality, Integrity, Availability

The **CIA Triad** is the foundation of cybersecurity.

- **Confidentiality** Keeping information private. Only the authorized people should see it. Example: Your bank account details, medical records, private messages, company secrets. If confidentiality breaks, data leaks, identity theft, embarrassment, blackmail. Tools/techniques: Encryption, access controls, strong passwords, VPNs.
- **Integrity** Making sure data stays accurate and unchanged unless authorized. No sneaky modifications. Example: Someone changes your exam marks, alters a bank transfer amount, modifies a medical prescription. If integrity is lost, wrong decisions, financial loss, even danger to life. Tools: Hashing/checksums, digital signatures, version control, write protections.
- **Availability** Making sure authorized users can access the data and systems when they need them. No blocking or crashing. Example: A hospital can't access patient records during an emergency, or an online shop goes down during Black Friday. If availability fails business stops, services unavailable, panic. Tools: Redundancy, backups, DDoS protection, reliable infrastructure.

1.3 Cyber Security terminology and taxonomy

- **Asset:** Anything valuable. Examples, Data, Laptop, Server, Customer information
- **Threat:** Anything that can potentially cause harm (a possible danger). Example: A skilled hacker, ransomware group, or even a careless employee.
- **Vulnerability:** A weakness in a system, code, process, or person that can be exploited. Example: Unpatched software bug, weak password, open port.
- **Risk:** The potential for loss when a threat exploits a vulnerability. $\text{Risk} = \text{Likelihood} \times \text{Impact}$. We try to reduce risk to acceptable levels.

Unit 1 Introduction to Cyber Security

- **Malware:** Malware is any software intentionally designed to damage systems, steal data, disrupt services, spy on users, gain unauthorized intent. It is written with malicious intent. Malware spreads through:

- Email attachments
- Infected websites
- Pirated software
- USB devices
- Network vulnerabilities
- Social engineering

Examples: Virus, Worm, Trojan, Ransomware, Spyware

- **Virus:** A **virus** is a malicious program that attaches itself to a legitimate file or program and spreads when the infected file is executed. A virus needs human action to spread. It cannot run by itself.

Characteristics:

- Requires host file
- Requires user action
- Spreads through file sharing
- Can modify or delete data

Examples: ILOVEYOU virus, Melissa virus, etc.

Worm: A worm is standalone malware that spreads automatically through networks. It does not need a host file and human action.

Characteristics:

- Self-replicating
- Fast spreading
- Consumes network bandwidth
- Can cause network crashes

Example: SQL Slammer

Trojan Horse: A Trojan is malware disguised as legitimate software. It looks safe but contains hidden malicious code.

Characteristics:

- Does NOT self-replicate
- Relies on social engineering
- Creates backdoor access
- Steals sensitive data

Types of Trojans: Backdoor Trojan, Banking Trojan, Remote Access Trojan, Downloader Trojan

Example: Zeus Trojan (banking)

Ransomware: Ransomware is malware that encrypts victim's data and demands ransom payment. (usually cryptocurrency)

Unit 1 Introduction to Cyber Security

Characteristics:

- Uses strong encryption
- Targets businesses and hospitals
- Causes huge financial loss
- Often spreads via phishing

Types: Crypto ransomware (encrypts files), Locker ransomware

Examples: WannaCry

Spyware: Spyware secretly monitors user activity and sends information to attacker. It focuses on: Data theft, Surveillance, Tracking. It can steal passwords, credit card numbers, browsing history, keystrokes.

Types: Record keystrokes

Example: FinFisher

- **Attack** (or exploit) — When someone actually uses a vulnerability to cause harm. The action taken by the threat actor.

1.5 Types of Attackers:

Not all bad guys are the same. Here's the common classification:

- **Hackers** (in the broad, neutral sense): People with deep technical skills who explore systems. Can be ethical (white-hat, good guys who help find weaknesses) or malicious.

Hacker Type	Intent	Typical Activities	Risk Level
White Hat (Ethical Hackers)	Defensive, authorized	Penetration testing, vulnerability scanning, security audits	Low – they strengthen systems
Black Hat	Malicious, unauthorized	Data theft, ransomware, phishing, exploiting vulnerabilities	High – criminal activity
Grey Hat	Mixed – unauthorized but not	Discovering flaws without permission,	Medium – unpredictable

Unit 1 Introduction to Cyber Security

	always malicious	sometimes reporting them	
Script Kiddies	Inexperience d, thrill- seeking	Using pre-made hacking tools without deep knowledge	Low– Medium – nuisance but can cause damage
Hacktivists	Political/soci al motives	Website defacement, DDoS attacks, leaking sensitive data	Medium– High – disrupt organization s
State/Nation- Sponsored Hackers	Espionage, cyber warfare	Attacking infrastructure, stealing military/corpora te secrets	Very High – geopolitical threat
Insider Threats	Employees misusing access	Stealing data, sabotaging systems	High – trusted access makes them dangerous
Red Hat (Vigilante Hackers)	Counter- attackers	Targeting black hats, dismantling malicious servers	Medium – unpredictabl e, sometimes illegal
Blue Hat	External testers invited by companies	Pre-release bug hunting, security validation	Low – controlled environment
Green Hat	Beginners learning hacking	Experimenting with exploits, training	Low – usually harmless curiosity

Unit 1 Introduction to Cyber Security

Elite Hackers	Highly skilled, advanced	Creating new exploits, leading cybercrime groups	Very High – difficult to defend against
Cryptojackers	Financial gain	Hijacking systems to mine cryptocurrency	Medium – drains resources
Botnet Operators	Control large networks of infected devices	Launching massive DDoS attacks, spam campaigns	High – large-scale disruption
Gaming Hackers	Target online games	Cheating, stealing accounts, exploiting in-game economies	Low– Medium – affects gaming industry

1.6 The Cyber Kill Chain

This is a very useful model from Lockheed Martin that shows how most advanced attacks (especially targeted ones) happen in stages. Think of it as a chain break one link, and you can stop the attack.

The classic 7 phases:

1. **Reconnaissance:** Reconnaissance is the first phase of a cyberattack. It's essentially the "information-gathering" stage where attackers (including crackers or malicious hackers) collect data about their target before launching an actual attack. Think of it as digital scouting — the attacker wants to know as much as possible about the system, network, or organization they plan to compromise.
2. **Weaponization:** Weaponization is the second phase of the Cyber Kill Chain, following reconnaissance. In this stage, attackers take the information they gathered about the target and create a malicious payload designed to exploit specific vulnerabilities. Essentially, it's where the attacker builds their "digital weapon."
3. **Delivery:** Delivery is the third phase of the Cyber Kill Chain, following weaponization. This is the stage where the attacker actually transmits the malicious payload to the target. If reconnaissance is about learning and weaponization is about building, then delivery is about launching the attack vector. The common methods for delivery:

Unit 1 Introduction to Cyber Security

- **Email Attachments:** Malicious files disguised as documents, spreadsheets, or PDFs.
 - **Phishing Links:** URLs that lead to exploit kits or malware downloads.
 - **Removable Media:** Infected USB drives or external hard drives.
 - **Web Applications:** Drive-by downloads from compromised websites.
 - **Network Services:** Exploiting open ports or vulnerable services directly.
4. **Exploitation:** Exploitation is the fourth phase of the Cyber Kill Chain, following delivery. At this stage, the malicious payload that was delivered to the target is triggered and executed, taking advantage of a vulnerability in the system. This is the moment when the attack moves from potential threat to active compromise. The things that may happen in exploitation are:
- The payload is activated (e.g., user opens a malicious file or clicks a link).
 - Vulnerabilities are exploited (software bugs, misconfigurations, weak passwords).
 - Malicious code runs on the target system, often escalating privileges.
 - The attacker gains initial access to the victim's environment.
5. **Installation:** Installation is the fifth phase of the Cyber Kill Chain, following exploitation. At this stage, the attacker's malicious code is installed on the target system to establish persistence and maintain access. This is where the attack becomes entrenched, allowing the attacker to control the compromised environment over time.
6. **Command and Control (C2):** Command and Control (C2) is the sixth phase of the Cyber Kill Chain, following installation. At this stage, the attacker establishes a communication channel between the compromised system and their remote server. This allows them to issue commands, exfiltrate data, and maintain control over the victim's environment
7. **Actions on Objectives:** Actions on Objectives is the final phase of the Cyber Kill Chain. At this stage, attackers have already gained access, established persistence, and set up command-and-control channels. Now, they move to achieve their ultimate goals — whether that's data theft, disruption, espionage, or financial gain

1.7 Security policies, standards, and best practices

Security Policy: Security Policy are formal, documented rules and guidelines that define how an organization protects its information assets, IT infrastructure, and data. It defines what must be protected, specify who is responsible. It establishes acceptable and unacceptable behavior. It provides a framework for enforcement and accountability.

Importance of Security Policies:

Security policies are essential for:

Unit 1 Introduction to Cyber Security

- **Align security with business objectives:** Policies ensure that protective measures support the company's mission rather than hamper it. For example, a retail business might prioritize secure customer payment systems, while a research firm focuses on safeguarding intellectual property.
- **Reduce risk exposure:** Reduce the chance of attack and reduce the damage if it happens.
- **Support legal and regulatory compliance:** means implementing cybersecurity controls, policies, and procedures to ensure that an organization follows all applicable laws, regulations, and industry standards related to data protection, privacy, and information security.
- **Establish accountability and governance:** means creating a clear structure of authority, responsibility, and oversight to ensure that cybersecurity is properly managed, monitored, and enforced within an organization.
- **Provide a foundation for incident response:** means establishing the policies, procedures, tools, roles, and controls that enable an organization to effectively detect, respond to, manage, and recover from cybersecurity incidents.

Role of Security Standards: Security standards provide structured frameworks and best-practice controls to implement security policies effectively. They:

- Translate high-level policies into measurable controls
- Provide audit criteria
- Ensure regulatory compliance
- Promote continuous improvement

Categorization of Security Policies: The security policies are generally structured hierarchically:

- **Enterprise Level:** High-level, organization-wide policies that define the overall security philosophy, objectives, and responsibilities.

Purpose of Enterprise Level:

- Establish security vision and direction
- Define governance structure
- Assign accountability
- Demonstrate management commitment

- **Issue specific Policies:** Policies that address specific security issues or risks.

Purpose of Issue specific Policies:

- Provide rules for particular topics
- Reduce specific risks
- Guide user behavior

Unit 1 Introduction to Cyber Security

- **System specific Policies:** Policies that define technical and operational requirements for specific systems or technologies.

Purpose of System specific Security Policies:

- Provide technical configuration guidance
- Define access control settings
- Ensure secure system operation

Information Security Policy (ISP): It defines the organization's overall approach to information security. It covers:

- Security governance
- Roles and responsibilities
- Risk management
- Compliance requirements

Acceptable use Policy: It defines acceptable behavior when using organizational IT resources. It covers:

- Internet usage
- Email usage
- Social media conduct
- Personal device usage

Data Protection Policy: It ensures proper handling of sensitive data. It covers:

- Data classification
- Encryption requirements
- Data retention
- Secure disposal

Access Control Policy: It defines how access to systems and data is granted and revoked. It covers:

- Authentication methods
- Authorization levels
- Least privilege principle
- Role based access control

Security Standards:

1. ISO/IEC 27001:

International standard for Information Security Management Systems (ISMS). It features are as follows:

Unit 1 Introduction to Cyber Security

- Risk based approach
- 114 security control (Annex A)
- Continuous improvement model (PDCA cycle)
- Certification available

Importance of ISMS:

- Globally recognized credibility
- Structured risk management
- Suitable for all industries

2. NIST SP 800-53

It is comprehensive catalog of security and privacy controls published by NIST (USA). It focuses on:

- Access control
- Audit and accountability
- Incident response
- System integrity

3. CIS Controls: A prioritized set of cybersecurity best practices developed by the Center for Internet. It focuses on:

- Inventory of assets
- Secure configuration
- Continuous vulnerability management
- Controlled use of administrative privileges.

Standards: More detailed, often mandatory ways to implement policies. Example: Use AES-256 encryption, enforce 12-character passwords with complexity.

Best Practices for Implementation

1 Conduct Regular Risk Assessments

- Identify vulnerabilities
- Analyze impact and likelihood
- Prioritize remediation

Example: Annual penetration testing to identify exploitable weaknesses.

2 Regular Security Audits

- Internal audits

Unit 1 Introduction to Cyber Security

- External third-party audits
- Compliance verification

Example: ISO 27001 surveillance audits ensure continuous compliance.

3 Employee Security Awareness Training

- Phishing simulations
- Password hygiene training
- Social engineering awareness

Example: Reduces phishing success rate significantly

Human error remains the top security risk.

4 Implement Strong Access Controls

- Multi-Factor Authentication (MFA)
- Least privilege
- Periodic access review

Mitigates insider threats and credential compromise.

5 Incident Response Planning

- Defined response teams
- Tabletop exercises
- Clear communication channels

Reduces response time during breaches.

6 Patch and Vulnerability Management

- Regular updates
- Automated scanning
- Risk-based prioritization

Prevents exploitation of known vulnerabilities.

7 Data Encryption

- Encrypt data at rest
- Encrypt data in transit (TLS)
- Key management policies

Protects data even if breached.

Unit 1 Introduction to Cyber Security

Overview of Security Models (Bella-LaPadula, Biba Model)

A security model is a formal framework that defines how security policies should be enforced within a computer system. It provides:

- Clear rules for controlling access to information
- A structured way to enforce confidentiality and integrity
- A foundation for designing secure operating systems and databases

Security models are important because they:

- Help prevent unauthorized access
- Protect sensitive data
- Reduce security risks
- Provide theoretical foundations for real-world security systems

Two of the most important classical security models are:

- **Bell-LaPadula Model:** Focused on confidentiality
- **Biba Model:** Focused on integrity

Bell-LaPadula Model:

The Bell-LaPadula model was developed in 1973 by David Bell and Leonard LaPadula for the U.S. Department of Defense.

Objective:

To protect confidentiality of data — ensuring that sensitive information is not disclosed to unauthorized users.

It is commonly used in systems that handle classified information such as:

- Military systems
- Government agencies
- Intelligence organizations

Point to be Remember

The model is based on security levels such as:

- *Top Secret*

Unit 1 Introduction to Cyber Security

- *Secret*
- *Confidential*
- *Unclassified*

These levels form a hierarchy.

1. Simple Security Property (No Read Up)

A subject (user/process) cannot read data at a higher security level. This is called "No Read Up" (NRU).

Example:

A user with "Confidential" clearance cannot read "Secret" documents. This prevents unauthorized viewing of sensitive information.

2. Star (*) Property (No Write Down)

A subject cannot write information to a lower security level. This is called "No Write Down" (NWD).

Example:

A "Top Secret" user cannot write data into a "Confidential" file. This prevents sensitive data from leaking to lower levels.

Implications for Confidentiality

The Bell-LaPadula model ensures:

- Sensitive data does not flow downward
- Users cannot access information beyond their clearance
- Information leakage is prevented

However, it does not focus on data integrity.

Applications:

The Bell-LaPadula model is used in:

- Military information systems
- Secure government databases
- Classified document management systems
- Multilevel secure operating systems

It is especially useful in environments where protecting secrecy is the top priority.

Unit 1 Introduction to Cyber Security

3. Biba Model

The Biba model was proposed by Kenneth J. Biba in 1977.

Objective:

To protect data integrity: ensuring data is accurate, trustworthy, and not improperly modified.

Unlike Bell-LaPadula, Biba focuses on preventing corruption rather than preventing disclosure.

Point to be Remember:

The Biba model also uses hierarchical integrity levels:

- High Integrity
- Medium Integrity
- Low Integrity

1. Simple Integrity Property (No Read Down)

A subject cannot read data at a lower integrity level.

This is called "No Read Down" (NRD)".

Example: A high-integrity process cannot read data from an untrusted (low integrity) source.

This prevents contamination from unreliable data.

2. Star Integrity Property (No Write Up)

A subject cannot write to a higher integrity level.

This is called "No Write Up" (NWU)".

Example: A low-integrity user cannot modify high-integrity system files.

This prevents unauthorized modification of critical data.

How Biba Protects Integrity

The Biba model ensures:

- Low-trust users cannot corrupt high-trust data
- Critical system files are protected from unauthorized modification

Unit 1 Introduction to Cyber Security

- Data accuracy and reliability are maintained

However, Biba does not focus on confidentiality.

Applications:

The Biba model is useful in:

- Banking systems (to protect transaction integrity)
- Financial record systems
- Industrial control systems
- Database management systems
- Healthcare record systems

It is ideal where accuracy and correctness are more important than secrecy.

Unit 1 Introduction to Cyber Security